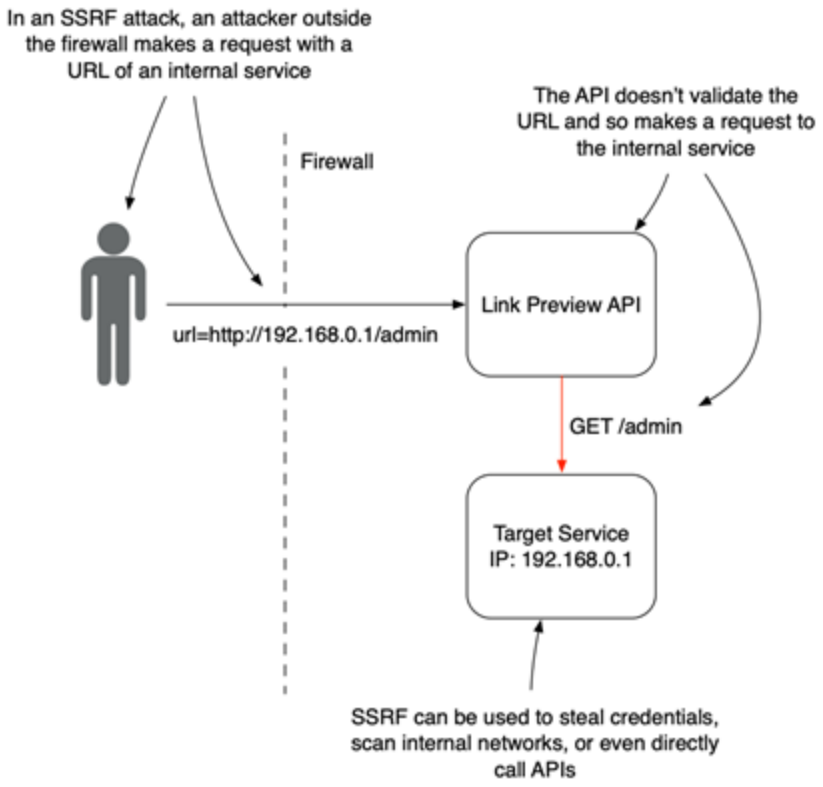


Figure 10.4 In a server-side request forgery (SSRF) attack, the attacker sends a URL to a vulnerable API that refers to an internal service. If the API doesn't validate the URL it will make a request to the internal service that the attacker couldn't make themselves. This may allow the attacker to probe internal services for vulnerabilities, steal credentials returned from these endpoints, or directly cause actions via vulnerable APIs.

SSRF attacks can be devastating in some cases. For example, in July 2019, Capital One, a large financial services company, announced a data breach that compromised user details, social security numbers, and bank account numbers (https://www.capitalone.com/about/newsroom/capital-one-announces-data-security-incident/). Analysis of the attack